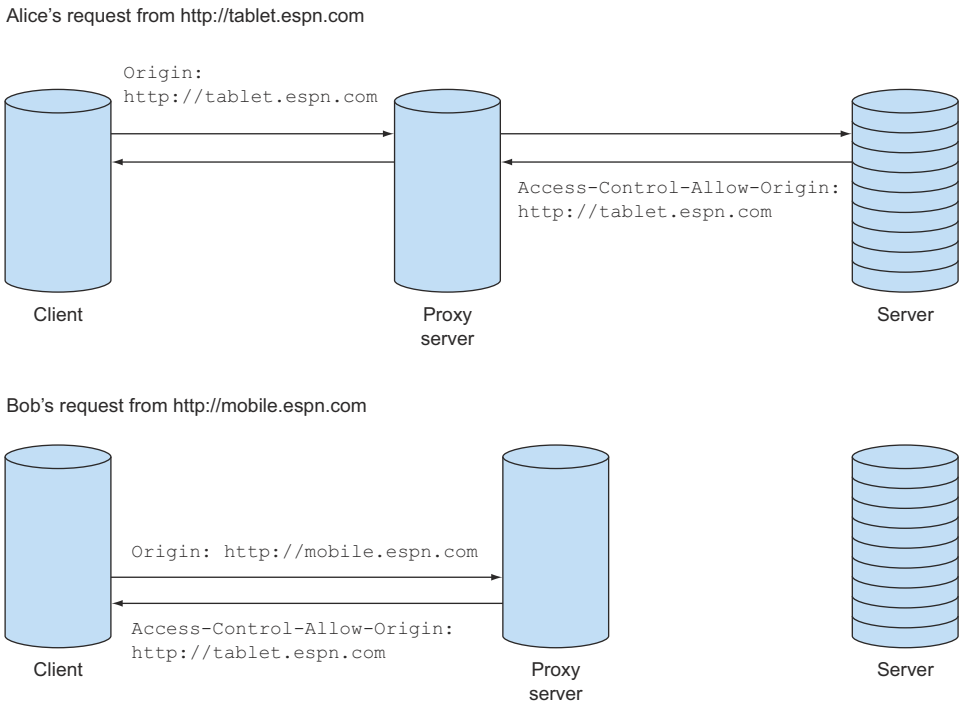


Figure 6.6 Example of how a proxy server could mix up Access-Control-Allow-Origin headers through caching

Bob is using his iPhone and visits http://mobile.espn.com, while Alice is using her tablet and visits http://tablet.espn.com. Because both Alice and Bob are at work, their requests flow through the company's proxy server.

When Alice makes the first request to http://tablet.espn.com, the tablet site makes a CORS request to load the scores from http://api.espn.com. The API responds with the header `Access-Control-Allow-Origin: http://tablet.espn.com`, and the proxy server caches the response.

Next, Bob makes his request to http://mobile.espn.com, and the mobile site grabs the scores from the same API. The proxy server notices that the request is to the same server that the tablet requested, and so it returns the cached response. Unfortunately, the cached response has the `Access-Control-Allow-Origin: http://tablet.espn.com` header set. This header causes a request from http://mobile.espn.com to fail, because the Origin header doesn't match the Access-Control-Allow-Origin header (figure 6.6).

Luckily, there is a way to fix this. The Vary header tells the proxy server that the Origin header should be taken into account when deciding whether or not to send cached content. With the `Vary: Origin` header in place, the proxy server will treat a request with `Origin: http://mobile.espn.com` differently from a request with `Origin: http://tablet.espn.com`.